

Four stages of penetration testing

While carrying out penetration testing, we should pay special attention to different problems and possible attack vectors. In this article, we will go through all the four stages of pen testing. We will also go through some open source tools that can be useful in each stage. A complete list of Kali Linux tools is available on the official website.

Preliminary penetration testing

In this first stage, the need is to gather information regarding the system on which we have to do testing. We must check if the system under test can be explored from the outside, and if attackers can pull out any data. For example, information about product architecture, technologies used, framework, ports, protocols, software versions and entry points may considerably increase the possibility of an attack's success. The goal is to shield this information, or at the very least to make it really difficult for a potential attacker to take it out from a product. Given below are some of the tools that will be helpful in this.

Amap: Amap sets up a connection with particular ports and sends trigger packets. Generally, trigger packets are application protocol handshakes. After sending the packets, Amap watches for matches in the response strings. Amap assists various types of protocols —TCP, UDP, binary, regular, and SSL-enabled ASCII protocols. This tool can also be used for recognising non-ASCII based applications.

The Amap package includes two tools.

amap crap: Tool for transferring random data to silent TCP, UDP, and SSL ports in order to trigger an unexpected response.

amap: An application for identifying applications running on a particular port.

Nmap: Network Mapper (Nmap) is a popular open source service for penetration testing and security testing. It can also be used for inventorying a

network, monitoring host and service uptimes, and managing service upgrade schedules.

Nmap uses raw IP packets to get complete information on the hosts existing on a network -- services offered by them, operating systems run by them, packet filters and firewalls that are implemented, etc. Nmap is well-suited for all popular operating systems and has official packages for Windows, Linux and macOS.

Nmap is one of the most accepted tools for host and network scanning. Its main features are its speed, universality, and effectiveness.

DNSMap: Testers regularly use DNSMap to verify infrastructure security and collect data about domain names, subdomains, IP netblocks, and more. This utility is also used for subdomain brute-force at the inventory stage. This process is especially helpful when other domain brute-force methods, such as zone transfer, don't come up with the desired output.

There are some more popular tools like SSLsplit, load balancing detector, Arp-scan, etc, that act in a similar fashion.

Analysing vulnerabilities

Vulnerability measurement is one of the most vital stages of penetration testing. Analysing vulnerabilities is quite similar to gathering information, but this time the goal is to discover the weaknesses that can be effectively exploited by an attacker. This stage plays a critical part in penetration testing because, in most cases, it is vulnerabilities that make our system or product open to cyber-attacks.

Knowledge of one or two efficient vulnerability assessment tools will be more helpful than trying to use dozens of tools concurrently. Given below are a few useful tools for this stage of pen testing.

APT2: APT2 is a desirable toolset for automated penetration testing. It carries out Nmap scanning and can also import the scanning results from other tools including Nessus and Nexpose.

APT2 has a general knowledge base, where it stores all collected module results on a local host. Users can retrieve APT2's knowledge base from the application, and use it to see the results received from an exploit module.

APT2 is highly flexible and thanks to the configurability of the Safe Level, it enables granular control over its behaviour. This tool is user-friendly and has comprehensive documentation.

BruteXSS: BruteXSS is a fast, cross-site scripting brute-force tool. Used mainly for brute forcing parameters, it can inject several payloads from one wordlist to one parameter, and scan the latter to observe if any are liable to the XSS vulnerability.

Features of BruteXSS include:

- XSS brute forcing
- XSS scanning
- Custom wordlists
- Support for GET/POST requests

But the main advantage of BruteXSS is its high level of precision.

Sniffing and spoofing traffic

The next stage in pen testing is traffic sniffing and spoofing. It helps to detect network vulnerabilities and weak spots that can be aimed by attackers. We can verify the paths taken by the packets within our network, and observe where and to whom these packets are being sent, the information they carry, whether they are encrypted well, etc. Given below are some Kali Linux tools that can help us do that.

Burp Suite: This popular Web application security testing software works as a proxy; therefore, all the requests from the Web browser pass through it. It authorises users to make changes in these requests as per their requirements, which is excellent for testing vulnerabilities like XSS or SQLi, or any other vulnerability associated with the Web.

Arpspoof: Arpspoof is a tool for intercepting packets on a local network with commutation. It redirects packets